

Chapter 1 Answer Key

Self-Assessment Questions

1. A. The audit scope is specific to a single audit and does not grant authority to perform an audit.
 B. A request from management to perform an audit is not sufficient because it relates to a specific audit.
C. The approved audit charter outlines the auditor's responsibility, authority and accountability.
 D. The approved audit schedule does not grant authority to perform an audit.
2. **A. The objective of control self-assessment (CSA) is to have business managers become more aware of the importance of internal control and their responsibility in terms of corporate governance.**
 B. Reducing audit expenses is not a key benefit of CSA.
 C. Improved fraud detection is important but not as important as control ownership. It is not a principal objective of CSA.
 D. CSA may give more insights to internal auditors, allowing them to take a more consultative role; however, this is an additional benefit, not the key benefit.
3. **A. A risk-based audit approach focuses on understanding the nature of the business and being able to identify and categorize risk. Business risk impacts the long-term viability of a specific business. Thus, an information systems (IS) auditor using a risk-based audit approach must be able to understand business processes.**
 B. Administrative controls, while an important subset of controls, are not the primary focus needed to understand the business processes within the scope of an audit.
 C. Like administrative controls, environmental controls are an important control subset; however, they do not address high-level overarching business processes under review.
 D. Business strategies are the drivers for business processes; however, in this case, an IS auditor is focusing on the business processes that were put in place to enable the organization to implement its strategies.
4. A. Control risk is the risk that a material error exists that will not be prevented or detected in a timely manner by the system of internal controls.
 B. Detection risk is the risk that a material misstatement with a management assertion will not be detected by an audit and assurance professional's substantive tests. It consists of two components: sampling risk and non-sampling risk.
C. Inherent risk is the risk level or exposure assessed without considering the actions that management has taken or might take.
 D. Sampling risk is the risk that incorrect assumptions are made about the characteristics of a population from which a sample is taken. Non-sampling risk is detection risk that is unrelated to sampling; it can be due to a variety of reasons, including human error.
5. A. An information systems (IS) auditor is not expected to ignore control weaknesses just because they are outside the scope of a current review.
 B. The conduct of a detailed systems software review may hamper the audit's schedule, and an IS auditor may not be technically competent to do such a review at the time of the audit.
 C. If there are control weaknesses that have been discovered by an IS auditor, they should be disclosed. By issuing a disclaimer, this responsibility would be waived.
D. The appropriate option would be to review the relevant systems software and recommend a detailed systems software review for which additional resources may be recommended.
6. A. Deployment of available audit resources is determined by the audit assignments, which are influenced by the planning process.
B. Short- and long-term issues that drive audit planning can be heavily impacted by changes to the risk environment, technologies and business processes of the enterprise.
 C. The audit charter reflects the mandate of top management to the audit function and resides at a more abstract level.
 D. Applicability of information systems (IS) audit standards, guidelines and procedures is universal to any audit engagement and is not influenced by short- and long-term issues.

7. A. **The objective of control self-assessment (CSA) is to have business managers become more aware of the importance of internal control and their responsibility in terms of corporate governance.**
 B. Reducing audit expenses is not a key benefit of CSA.
 C. Improved fraud detection is important but not as important as control ownership. It is not a principal objective of CSA.
 D. CSA may give more insights to internal auditors, allowing them to take a more consultative role; however, this is an additional benefit, not the key benefit.
8. A. The findings of a previous audit are of interest to the auditor, but they are not the most critical step. The most critical step involves finding the current issues or high-risk areas, not reviewing the resolution of older issues. A review of historical audit findings could indicate that management is not resolving the risk items identified or that the recommendations were ineffective.
 B. Executive management is not required to approve the audit plan. It is typically approved by the audit committee or board of directors. Management could recommend areas to audit.
 C. Reviewing information security policies and procedures is normally conducted during fieldwork, not planning.
 D. **Of all the steps listed, performing a risk assessment is the most critical. Risk assessment is required by ISACA IS Audit and Assurance Standard 1201 (Risk Assessment in Planning), statement 1201.2: "IT audit and assurance practitioners shall identify and assess risk relevant to the area under review when planning individual engagements." In addition to the standards requirement, if a risk assessment is not performed, then high-risk areas of the auditee systems or operations may not be identified for evaluation.**
9. A. **Audit planning requires a risk-based approach.**
 B. Materiality pertains to potential weaknesses or absences of controls while planning a specific engagement, and whether such weaknesses or absences of controls could result in a significant deficiency or a material weakness.
 C. Fraud monitoring pertains to the identification of fraud-related transactions and patterns and may play a part in audit planning but only as it pertains to organizational risk.
- D. Sufficiency of audit evidence pertains to the evaluation of the sufficiency of evidence obtained to support conclusions and achieve specific engagement objectives.
10. A. Preventive controls are those that avert problems before they arise. Backup media cannot be used to prevent damage to files and, therefore, cannot be classified as preventive controls.
 B. Management controls modify processing systems to minimize repeat occurrences of the problem. Backup media do not modify processing systems and, therefore, do not fit the definition of management controls.
 C. **A corrective control helps to correct or minimize the impact of a problem. Backup media can be used for restoring the files in case of damage to the files, thereby reducing the impact of a disruption.**
 D. Detective controls help to detect and report problems as they occur. Backup media do not aid in detecting errors.

Chapter 1 Answer Key

Case Study

1. A. Performing a survey audit of logical access controls would occur after an IT risk assessment.
 B. Revising the audit plan to focus on risk-based auditing would occur after an IT risk assessment.
C. An IT risk assessment should be performed first to ascertain which areas present the greatest risk and which controls mitigate that risk. Although narratives and process flows have been created, the organization has not yet assessed which controls are critical.
 D. Testing controls that the IS auditor feels are most critical would occur after an IT risk assessment.
2. A. **The system administrator account being known by everybody is most dangerous. In that case, any user could perform any action in the system, including accessing files and making permission and parameter adjustments.**
 B. Infrequent password changing would present a concern but would not be as serious as everyone knowing the system administrator account.
 C. The network administrator being given excessive permissions would present a concern, but it would not be as serious as everyone knowing the system administrator account.
 D. The absence of a privilege management policy would be a concern, but it would not be as serious as everyone knowing the system administrator account.
3. A. When a sample is chosen from a set of control documents, there is no way to ensure that every change is accompanied by appropriate control documentation.
B. When testing a control, it is advisable to trace from the item being controlled to the relevant control documentation. When a sample is chosen from a set of control documents, there is no way to ensure that every change is accompanied by appropriate control documentation. Accordingly, changes to production code provide the most appropriate basis for selecting a sample.
 C. When a sample is chosen from a set of control documents, there is no way to ensure that every change is accompanied by appropriate control documentation.
 D. When testing a control, it is advisable to trace from the item being controlled to the relevant control documentation.
4. Some possible answers include:
 - The IS auditor can check which account was recently used for executing a particular system administrator task.
 - The IS auditor can check if there was a change record for any selected system changes (e.g., server reboot and patching).
 - The IS auditor can check the transactions to see if they separated the incompatible duties.
5. A. Previous IS audit reports will be revisited to save redundant work and to use as references when doing the IS audit work.
B. The audit charter defines the purpose, authority and responsibility of the IS audit activities. It also sets the foundation for upcoming activities.
 C. Impact of employee turnover would be addressed when negotiating follow-up activities for respective areas if there is any gap to close.
 D. Impact of the implementation of a new ERP would be addressed when negotiating the follow-up activities for respective areas if there is any gap to close.
6. A. The service auditor's report cannot ensure the discovery of control inefficiencies.
 B. Review of the contract cannot ensure the discovery of control inefficiencies.
 C. Comparing the service delivery report and the service level agreement cannot ensure the discovery of control inefficiencies.
D. IS audit should conduct an independent review of the backup and batch processing. All other choices cannot ensure the discovery of control inefficiencies in the process.
7. A. This is not an example of inherent risk. Inherent risk is the risk level or exposure without considering the actions that management has taken or might take (e.g., implementing controls).
 B. This is not an example of residual risk. Residual risk is the remaining risk after management has implemented a risk response.
C. Control risk exists when a risk cannot be prevented or detected on a timely basis by the system of IS controls, which is described in this instance.

D. This is not an example of material risk. Material risk is any risk large enough to threaten the overall success of the business in a material way.

8. Possible answer: The COBIT framework can be leveraged and adapted. Each process can be

classified as fully addressed, partially addressed and not applicable by comparing the standard COBIT framework to the organization's reality. Further frameworks, standards and practices can be included in each respective process, as COBIT guidance suggests.

Chapter 2 Answer Key

Self-Assessment Questions

1.
 - A. A central document repository hosts a great deal of data but not necessarily the specific information that would be useful for monitoring and compliance.
 - B. A knowledge management system provides valuable information but generally is not used by management for compliance purposes.
 - C. A dashboard provides information that illustrates compliance with the processes, applications and configurable elements and keeps the enterprise on course.**
 - D. Benchmarking provides information to help managers adapt the enterprise promptly, according to trends and environment.
2.
 - A. Specifications for planned hardware purchases are not strategic items.
 - B. Information systems (IS) strategic plans must address the needs of the business and meet future business objectives. Hardware purchases may be outlined, but not specified, and neither budget targets nor development projects are appropriate choices.**
 - C. Target dates for development projects are not strategic items.
 - D. Annual budgetary targets for the IT department are not strategic items.
3.
 - A. Typically, the IT department will have short- or long-range plans that are consistent and integrated with the organization's plans.
 - B. Plans must be time- and project-oriented and address the enterprise's broader plans toward attaining its goals.
 - C. Long-range planning for the IT department should recognize enterprise goals, technological advances and regulatory requirements.**
 - D. Short-range planning for the IT department should be integrated into the short-range plans of the enterprise to better enable the IT department to be agile and responsive to needed technological advances that align with enterprise goals and objectives.
4.
 - A. A data security officer's prime responsibility is recommending and monitoring data security policies.**
 - B. Promoting security awareness within the enterprise is one of the responsibilities of a data security officer. However, it is less important than recommending and monitoring data security policies.
 - C. The IT department, not the data security officer, is responsible for establishing procedures for IT security policies recommended by the data security officer.
 - D. The IT department, not the data security officer, is responsible for the administration of physical and logical access controls.
5.
 - A. An effective enterprise risk management (ERM) framework is not a key success factor for an information security program.
 - B. Senior management's commitment provides the basis for success in implementing an information security program.**
 - C. Although an effective information security budgeting process will contribute to success, senior management commitment is the key element.
 - D. Program planning is important but will not be sufficient without senior management commitment.
6.
 - A. Evaluating the activities of boards and committees providing oversight is an important aspect of governance and should be measured.**
 - B. Providing strategic IT drivers is irrelevant to evaluating IT governance performance measures.
 - C. Adhering to regulatory reporting standards and definitions is irrelevant to evaluating IT governance performance measures.
 - D. Evaluating the IT department is irrelevant to evaluating IT governance performance measures.
7.
 - A. The roles of security administration and change management are incompatible functions. The level of security administration access rights could allow changes to go undetected.
 - B. Computer operations and system development is the incorrect choice because this would make it possible for an operator to run a program they had amended.
 - C. The combination of system development and change control would allow program modifications to bypass change control approvals.
 - D. It is common for system development and maintenance to be undertaken by the same**

person. In both, the programmer requires access to the source code in the development environment but should not be allowed access in the production environment.

8.
 - A. Approval of database administration (DBA) activities does not prevent the combination of conflicting functions. Review of access logs and activities is a detective control.
 - B. Separation of duties (SoD) will prevent the combination of conflicting functions. This is a preventive control, and it is the most critical control over DBA.**
 - C. Reviewing access logs and activities may not reduce the risk if DBA activities are improperly approved.
 - D. Reviewing the use of database tools does not reduce the risk because this is only a detective control and does not prevent the combination of conflicting functions.

9.
 - A. Origination, in conjunction with recording and correction, does not enable the transaction to be authorized for processing and committed within the system of record.
 - B. Authorization should be separated from all aspects of record keeping (origination, recording and correction). Such a separation enhances the ability to detect the recording of unauthorized transactions.**
 - C. Recording, in conjunction with origination and correction, does not enable the transaction to be authorized for processing and committed within the system of record.
 - D. Correction, in conjunction with origination and recording, does not enable the transaction to be authorized for processing and committed within the system of record.

10.
 - A. Logging changes to development libraries would not detect changes to production libraries.
 - B. In smaller enterprises, it generally is not appropriate to recruit additional staff to achieve a strict separation of duties. The IS auditor must look at alternatives.
 - C. The information systems (IS) auditor should recommend processes that detect changes to production source and object code, such as code comparisons, so that the changes can be reviewed by a third party regularly. This would be a compensating control process.**
 - D. Access controls to prevent the operator from making program modifications require a third party to make the changes, which may not be practical in a small enterprise.

Chapter 2 Answer Key

Case Study

1. A. **IT loses sight of the enterprise direction without explicit strategy documents, making project selection harder and service levels difficult to define. Overall, IT becomes suboptimal in delivery and value realization.**
 - B. The failure of the risk management committee to hold regular meetings and produce good documentation implies a lack of good risk governance. Risk follows when setting the business and IT objectives.
 - C. Although an inadequate budget for future IT investments raises concern, this is less important than an incomplete strategy.
 - D. The lack of a full-time CIO may be a concern, but it is not as important as an incomplete strategy.
2. A. The behavior related to application programmers' access and migration code represents a lack of IT policies and procedures.
 - B. **The lack of IT policies and procedures makes IT-related work inconsistently delivered. The policy reflects management intentions and norms set by the strategy. The procedures are instrumental to day-to-day IT delivery.**
 - C. Risk management practices do not have to compare to peer enterprises.
 - D. Although the reporting structure for IT is important, it is not as critical as IT policies and procedures.
3. A. Not having a full-time CIO may be a concern but is not as concerning as the information systems manager reporting to the CFO.
 - B. The lack of an IT steering committee may cause issues but is not as big a concern as the information systems manager reporting to the CFO.
 - C. The board of directors playing a major role in IT initiatives is not a major concern.
 - D. **The IS manager should ideally report to the board of directors or the CEO to provide sufficient independence. The reporting structure that requires the IS manager to report to the CFO is not desirable and could compromise certain controls.**
4. A. **Application programmers should obtain approval from the business owners before accessing data. DBAs are only custodians of the data and should provide only the access authorized by the data owner.**
 - B. Although this may be an issue, it is not as big a SoD concern as the DBA approving direct-write access.
 - C. The internal audit department reporting to the CFO is not as big a SoD concern as the DBA approving direct-write access.
 - D. This is not as big a SoD concern as the DBA approving direct-write access.
5. A. This does not best mitigate tampering with data.
 - B. Handing program code to the librarian does not best mitigate tampering with data.
 - C. The reporting structure does not mitigate data tampering.
 - D. **Sign-off on data contained in the financial results by the business managers at the end of the month would detect any significant discrepancies that can result from the tampering of data through inappropriate direct access of the data gained without the approval or knowledge of the business managers.**
6. **Possible answer:** The CFO may act as the CIO in a small enterprise. Having the internal control department report to a different executive (e.g., HR or risk management) is better. The governance function should exist to carry out the IT strategy and the IT steering committee direction. SoD should be maximized to the degree possible. Compensating controls, such as supervisory or peer reviews, can be applied to current controls.
7. **Possible answer:** An IT budgeting and investment process should be defined and align with the Accenco enterprise cycles (e.g., fiscal year, quarterly reviews). The financial management process should include budgeting activity that states its budgeting approach, the cost structure following the chart of accounts and the approval chain. The business case process should be used to justify the process and persuade the board to approve it.
8. **Possible answer:** In this case, the internal auditor should seek further assurance (e.g., monitoring of IS controls by tools, benchmarking efforts by the procurement team, *ad hoc* external auditing or senior management review from the board).

Chapter 3 Answer Key

Self-Assessment Questions

1. **A. Test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.**
 - B. Although it is important that the data set be complete, the primary concern is that test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.
 - C. Although it is important to encompass a representation of the transactional data, the primary concern is that test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.
 - D. Although it is important that the data set represent current data being processed, the primary concern is that test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.
2. **A. Parallel testing may show that the old system is more cost-effective than the new system, but this is not the primary reason.**
 - B. Unit and system testing are completed before parallel testing.
 - C. Program interfaces with files are tested for errors during system testing.
 - D. The purpose of parallel testing is to ensure that the implementation of a new system will meet user requirements.**
3. **A. Management should be informed immediately to determine whether they are willing to accept the potential material risk of not having that preventive control in place.**
 - B. The existence of a detective control instead of a preventive control usually increases the risk that a material problem may occur.
 - C. Often, during business process reengineering (BPR), many nonvalue-added controls are eliminated. This is good, unless the controls increase the business and financial risk.
 - D. An IS auditor may want to monitor, or recommend that management monitor, the new process, but this should be done only after management has been informed and accepts the risk of not having the preventive control in place.
4. **A. A range check is checking data that match a predetermined range of values.**
 - B. A check digit is a numeric value that is calculated mathematically and appended to data to ensure that the original data have not been altered (e.g., an incorrect, but valid, value substituted for the original). This control is effective in detecting transposition and transcription errors.**
 - C. An availability check is programmed checking of the data validity in accordance with predetermined criteria.
 - D. In a duplicate check, new or fresh transactions are matched to those previously entered to ensure that they are not already in the system.
5. **A. A lack of review of access controls in a financial enterprise can have serious consequences given the types of data and assets that can be accessed.**
 - B. A lack of documentation may not be as serious as not having properly reviewed access controls.
 - C. It may not be possible to retrieve data from two-year-old backup media.
 - D. It may be acceptable to the business to perform database backups once a day, depending on the volume of transactions.
6. **A. A project timetable normally is not found in a requirements document.**
 - B. Assessing the vendor quality processes comes after the requirements have been completed.
 - C. The decision to purchase a package from a vendor comes after the requirements have been completed.
 - D. The purpose of the requirements phase is to specify the functionality of the proposed system; therefore, an information systems (IS) auditor would concentrate on the completeness of the specifications.**
7. **A. With a purchased package, the design and development phases of the traditional life cycle are replaced with selection and configuration phases. A proposal from the supplier of packaged systems is requested and evaluated against predefined criteria for selection, before a decision is made to purchase the software. After the software is purchased, it is configured to meet the enterprise's requirements.**
 - B. The other phases of the system development life cycle (SDLC), such as feasibility study,

requirements definition, implementation and postimplementation, remain unaltered.

- C. The other phases of the SDLC, such as feasibility study, requirements definition, implementation and postimplementation, remain unaltered.
 - D. In this scenario, the design and development phases of the traditional life cycle are replaceable with selection and configuration phases.
8. A. Quality assurance (QA) has its focus on formal aspects of software development, such as adhering to coding standards or a specific development methodology.
- B. To fail at user specifications implies that requirements engineering has been done to describe the users' demands. Otherwise, there would not be a baseline of specifications against which to check.
- C. **Project management failed to either set up or verify controls that provide for software or software modules under development that adhere to those user specifications.**
- D. A failure to meet user specifications might show up during user training or acceptance testing but is not the cause.
9. A. Because the other elements do not need to change, the integrity risk is not increased.
- B. Because the other elements do not need to change, the concurrency risk is not increased.
- C. Because the other elements do not need to change, the confidentiality risk is not increased.
- D. **The main change when using thin client architecture is making the servers critical to the operation. Therefore, the probability that one of them fails is increased and, as a result, the availability risk is increased.**
10. A. Project documentation is generally second to actual functionality for agile development methodology.
- B. Strict standard operating procedures would be detrimental to a developer's ability to think creatively and collaboratively.
- C. All development methodologies require some form of requirements definition. Agile relies on clear requirements being defined up front.
- D. **Tacit knowledge (i.e., implicit knowledge gained from experience and difficult to document) is leveraged greatly by agile methods to increase**

collaboration and creativity of development teams.

Chapter 3 Answer Key

Case Study

1. A. Unpatched database servers are located on a screened subnet; this mitigates the risk to the enterprise.
B. Use of WEP encryption presents the most significant risk because WEP uses a fixed secret key that is easy to break. Transmission of credit cardholder information by wireless registers is susceptible to interception and presents a very serious risk.
 C. Sending credit cardholder data over the Internet is less of a risk because strong encryption is being used.
 D. Because the sales data being sent to the third party are aggregate data, no cardholder information should be included.
2. A. According to the case study, it is unclear whether the POS registers already use two-factor authentication. It is known that aggregate sales data are copied onto other media as-is, without any controls, for external distribution.
 B. According to the case study, it is unclear whether the wireless access points use MAC address filtering. It is known that aggregate sales data are copied onto other media as-is, without any controls, for external distribution.
 C. Compliance with the GDPR, although important, is not the most important due to the current operations being only in the United States, and the potential for expansion into the EU is a long-term vision for the enterprise.
D. It is unclear whether sales data are secure and free of personally identifiable information, such as credit card information and Social Security numbers. This presents the most significant risk and should be addressed.
3. **A. If internal audit is part of the steering committee, then it will have a say in the compliance and security-related controls to be included in production releases.**
 B. Ensuring database compliance is an operational responsibility and not an audit responsibility.
 C. Compatibility with existing architecture must be a function of the database implementation project team as a whole, which can include internal audit and also includes operations. Therefore, it is not the best answer choice.
 D. Although it is important that the upgraded database solution be compliant with all regulations affecting the enterprise, such a review should not be limited to one regulation. Therefore, it is not the best choice of those answers provided.
4. A. Functional project specifications should be executed by users and systems analysts, and not by the auditor.
 B. To propose to be project consultant for quality would not bring about an essential contribution, because quality is a formal characteristic; whereas, in the current case, the problem is substantial system instability.
C. The only appropriate action is additional research, even if the apparently technical nature of the problem renders it unlikely that the auditor may find it alone.
 D. To contact the project leader and redesign the schedule of deliveries would not solve the problem. Furthermore, the definition of real causes may sensibly alter the project environment.

Chapter 4 Answer Key

Self-Assessment Questions

1. A. User satisfaction is the measure to ensure that an effective information processing operation meets user requirements.
 B. Goal accomplishment evaluates the effectiveness involved in comparing performance with predefined goals.
C. Benchmarking provides a means of determining the level of performance offered by similar information processing facility (IPF) environments.
 D. Capacity and growth planning are essential due to the importance of IT in organizations and the constant technological change.
2. A. Mobile sites are specially designed trailers that can be quickly transported to a business location or to an alternate site to provide a ready-conditioned information processing facility (IPF).
 B. Warm sites are partially configured, usually with network connections and selected peripheral equipment—such as disk drives and controllers—but without the main computer.
 C. Cold sites have only the basic environment to operate an IPF. Cold sites are ready to receive equipment but do not offer any components at the site before the need.
D. Hot sites are fully configured and ready to operate within several hours or, in some cases, even minutes.
3. **A. When testing change management, the information systems (IS) auditor should start with system-generated information, containing the date and time a module was last updated, and trace from there to the documentation authorizing the change.**
 B. Focusing exclusively on the accuracy of the documentation examined does not ensure that all changes were, in fact, documented.
 C. To trace in the opposite direction would run the risk of not detecting undocumented changes.
 D. Focusing exclusively on the completeness of the documentation examined does not ensure that all changes were, in fact, documented.
4. **A. Virtual private network (VPN) technology allows external partners to securely participate in the extranet using public networks as a transport or shared private network. Because of low cost, using public networks (Internet) as a transport is the principal method. VPNs rely on tunneling/encapsulation techniques, which allow the Internet Protocol (IP) to carry a variety of different protocols (e.g., systems network architecture [SNA] and internetwork packet exchange [IPX]).**
 B. Client-server does not address extending the network to business partners (i.e., client-server refers to a group of computers within an organization connected by a communications network where the client is the requesting machine and the server is the supplying machine).
 C. Although it may be technically possible for an enterprise to extend its intranet using dial-up access, it would not be practical or cost effective to do so.
 D. A network service provider may provide services to a shared private network by providing Internet services, but it does not extend an organization's intranet.
5. **A. The criticality classification is determined by the role of the application system in supporting the strategy of the organization.**
 B. The replacement cost of the application does not reflect the relative value of the application to the business.
 C. Vendor support is not a relevant factor for determining the criticality classification.
 D. The associated threats and vulnerabilities will be evaluated only if the application is critical to the business.
6. **A. System utilities may enable unauthorized changes to be made to data on the client-server database. In an audit of database security, the controls over such utilities would be the primary concern of the information systems (IS) auditor.**
 B. Application program generators are an intrinsic part of client-server technology, and the IS auditor would evaluate the controls over the generator's access rights to the database rather than their availability.
 C. Security documentation should be restricted to authorized security staff, but this is not a primary concern.
 D. Access to stored procedures is not a primary concern.

7. A. Reviewing the validity of password changes would be performed as part of substantive testing.
 B. Understanding the network architecture and design is the starting point for identifying the various layers of information and the access architecture across the various layers, such as client-server applications.
C. The first step in auditing a network is to understand the network architecture and design. Understanding the network architecture and design provides an overall picture of the network and its connectivity.
 D. Understanding the network architecture and design is the starting point for identifying the various layers of information and the access architecture across the various layers, such as proxy servers and firewalls.

8. **A. The information systems (IS) auditor should always be present when disaster recovery plans (DRP) are tested to ensure that the tested recovery procedures meet the required targets for restoration, that recovery procedures are effective and efficient, and to report on the results as appropriate.**
 B. IS auditors may be involved in overseeing plan development, but they are unlikely to be involved in the actual development process.
 C. Similarly, an audit of plan maintenance procedures may be conducted, but the IS auditor normally would not have any responsibility for the actual maintenance.
 D. An IS auditor may be asked to comment upon various elements of a supplier contract, but this is not always the case.

9. **A. Recovery point objective (RPO) is the earliest point in time at which it is acceptable to recover the data. In other words, RPO indicates the age of the recovered data (i.e., how long ago the data was backed up or otherwise replicated). If RPO is very low, such as minutes, it means that the organization cannot afford to lose even a few minutes of data. In such cases, data mirroring (synchronous data replication) should be used as a recovery strategy.**
 B. If RPO is high, such as hours, then other backup procedures could be used.
 C. A high recovery time objective (RTO) means that the IT system may not be needed immediately after the disruption/declaration of disaster (i.e., it can be recovered later).

- D. RTO is the time from the disruption/declaration of disaster during which the business can tolerate the nonavailability of IT facilities. If RTO is high, slower recovery strategies that bring up IT systems and facilities can be used.**

10. A. Members of the organization's senior management are primarily responsible for overseeing the development of the business continuity plan (BCP) and are accountable for the results.
 B. Management is also accountable for selecting and approving the strategies used for disaster recovery.
 C. IT may be involved in declaring a disaster but is not primarily responsible.
D. The IT department of an organization is primarily responsible for restoring the IT systems and data after a disaster within the designated timeframes.

Chapter 4 Answer Key

Case Study

1. **A. Lack of encryption is the most important concern since microwave radio systems are easy to tap.**
 - B. Lack of scalability is important but not as important as ensuring the confidentiality and integrity of customer data.
 - C. The likelihood of a service outage is important but not as important as ensuring the confidentiality and integrity of customer data.
 - D. Cost overruns in implementation are important but not as important as ensuring the confidentiality and integrity of customer data.
2. **A. Scanning for malware would not detect the use of investigative tools designed to harvest passwords or reveal network vulnerabilities.**
 - B. Isolating the wireless network by placing it on a firewalled subnet would best reduce the likelihood of attack.**
 - C. Logging access would not prevent a successful attack.
 - D. Limiting access to normal business hours would not prevent a successful attack.
3. **A. Because not all employee job functions are critical during a disaster, it is not necessary to contract the same number of desktops at a recovery facility as the number of employees.**
 - B. Similarly, not every server is critical to the continued operation of the business. Only a subset will be required.
- C. Because there is no assurance that the hot site will not already be occupied, storing backup media at the facility would not be advisable. These facilities are generally not designed to provide extensive media storage, and frequent testing by other customers could compromise the security of the media.**
- D. As equipment needs in a rapidly growing business are subject to frequent change, quarterly reviews are necessary to ensure that the recovery capability keeps pace with the organization.**
4. **A. Adding each branch to the hot site contract would be far more expensive.**
 - B. The most cost-effective solution is to recommend that branches have sufficient capacity to accommodate critical personnel from another branch. Because critical job functions would represent only perhaps 20 percent of the staff from the affected branch, accommodations for only four to seven critical staff members would be needed.**
 - C. Relocating branch servers to the data center could result in performance issues. It would not address the question of where to locate displaced employees.
 - D. Adding capacity to the hot site contract would not provide coverage, as hot site contracts base their pricing on each location covered.

Chapter 5 Answer Key

Self-Assessment Questions

1. **A. The most important aspect of a signature-based intrusion detection system (IDS) is its ability to protect against known (signature) intrusion patterns. Such signatures are provided by the vendor and are critical to protecting an enterprise from outside attacks.**
 - B. One of the key disadvantages of an IDS is its inherent inability to scan for vulnerabilities at the application level.
 - C. An IDS cannot break encrypted data packets to identify the source of the incoming traffic.
 - D. A demilitarized zone (DMZ) is an internal network segment in which systems (e.g., a web server) accessible to the public are housed. In order to provide the greatest security and efficiency, an IDS should be placed behind the firewall so that it will detect only those attacks/intruders that enter the firewall.
2. **A. Logging access to personal information is a good control in that it will allow access to be analyzed if there is concern over unauthorized access. However, it will not prevent access.**
 - B. Restricting access to sensitive transactions will restrict access only to some of the data. It will not prevent access to other data.
 - C. The server and system security should be defined to allow only authorized staff members access to information about the staff whose records they handle on a day-to-day basis.**
 - D. Restricting system access to business hours would only affect when unauthorized access could occur and would not prevent such access at other times. It is important to consider that the data owner is responsible for determining who is allowed access via the written software access rules.
3. **A. The security officer serving as the database administrator, while a control weakness, does not carry the same disastrous impact as the absence of password controls.**
 - B. The absence of password controls on the two database servers, where production data resides, is the most critical weakness.**
 - C. Having no business continuity plan (BCP) for the mainframe system's noncritical applications, while a control weakness, does not carry the same disastrous impact as the absence of password controls.
- D. Local area networks (LANs) not backing up regularly, while a control weakness, does not carry the same disastrous impact as the absence of password controls.**
4. **A. If a password is disclosed when single sign-on (SSO) is enabled, there is a risk that unauthorized access to all systems will be possible.**
 - B. User access rights should remain unchanged by SSO, as additional security parameters might not be implemented.
 - C. One of the intended benefits of SSO is the simplification of security administration.
 - D. One of the intended benefits of SSO is the unlikelihood of an increased workload.
5. **A. To ensure that quality of service (QoS) requirements is achieved, the Voice over Internet Protocol (VoIP) service over the wide area network should be protected from packet losses, latency or jitter. To reach this objective, network performance can be managed to provide QoS and class of service support using statistical techniques, such as traffic engineering.**
 - B. The standard bandwidth of an integrated services digital network (ISDN) data link would not provide the QoS required for corporate VoIP services.
 - C. Wired equivalent privacy is an encryption scheme related to wireless networking.
 - D. VoIP phones are usually connected to a corporate local area network (LAN) and are not analog.
6. **A. Benefits of cloud computing are redundancy and the ability to access systems and data in the event of a technical failure.**
 - B. Considering that an insurance company must preserve the privacy/confidentiality of customer information, unauthorized access to information and data leakage are the major concerns.**
 - C. The ability to investigate an incident is important, but most important is addressing the risk of an incident: the exposure of sensitive data.
 - D. If a cloud provider goes out of business, the data should still be available from backups.

7. A. A digital signature provides authentication and integrity.
B. Tunnel mode provides encryption and authentication of the complete (Internet Protocol) IP package. To accomplish this, the authentication header (AH) and encapsulating security payload (ESP) services can be nested.
 C. A digital certificate provides authentication and integrity.
 D. The transport mode provides primary protection for the protocols' higher layers (i.e., protection extends to the data field [payload] of an IP package).

8. A. **A digital signature includes an encrypted hash total of the size of the message as it was transmitted by its originator. This hash would no longer be accurate if the message were subsequently altered, indicating that the alteration had occurred.**
 B. Digital signatures will not identify, prevent or deter unauthorized reading.
 C. Digital signatures will not identify, prevent or deter theft.
 D. Digital signatures will not identify, prevent or deter unauthorized copying.

9. A. **This best describes a distributed denial of service (DDoS) attack. Such attacks are centrally initiated and involve the use of multiple compromised computers. The attacks work by flooding the target site with spurious data, thereby overwhelming the network and other related resources. To achieve this objective, the attacks need to be directed at a specific target and occur simultaneously.**
 B. DDoS attacks are not locally initiated.
 C. DDoS attacks are not initiated using a primary computer.
 D. DDoS attacks are not staggered.

10. A. Scanning email attachments on the mail server is a preventive control. It will prevent infected email files from being opened by the recipients, which would cause their machines to become infected.
 B. Restoring systems from clean copies is a preventive control. It will ensure that viruses are not introduced from infected copies or backups, which would reinfect machines.
 C. Disabling universal serial bus (USB) ports is a preventive control. It prevents infected files from being copied from a USB drive onto a machine, which would cause the machine to become infected.
D. Antivirus software can be used to prevent virus attacks. Running regular scans can be useful to detect virus infections that have already occurred. Regular updates of the software are required to ensure it can update, detect and treat viruses as they emerge.

Chapter 5 Answer Key

Case Study

1.
 - A. On an enterprise's internal network, security policies and controls should be in place to detect and halt an outside attack that uses an internal machine as a staging platform. Therefore, this would not be the biggest concern to the IS audit.
 - B. Computers at the backup site are subject to the corporate security policy and therefore are not high-risk computers.
 - C. **VPN offers a secure connection between the remote PC and the corporate network. VPN does not, however, protect the remote PC from outside attack (such as from the Internet). If the remote PC is compromised, a malicious actor can use the entry point of the compromised remote PC to enter the corporate network (lateral movement).**
 - D. Computers on the network that are at the enterprise's remote offices, perhaps with IS and security employees who have different ideas about security, are riskier than computers in the main office or backup site, but obviously less risky than home computers.
2.
 - A. **The greatest degree of protection in applying access control software against internal and external users' unauthorized access is at the network and platform/OS levels. These systems are also referred to as general support systems, and they make up the primary infrastructure on which applications and database systems will reside.**
 - B. The application level is part of the infrastructure made up by the general support systems, supported by the network and OS level.
 - C. The database level is part of the infrastructure made up by the general support systems, supported by the network and OS level.
 - D. The log file level is part of the infrastructure made up by the general support systems, supported by the network and OS level.
3.
 - A. When an employee reports a forgotten password, the security administrator should start a password process generation procedure only after verifying the user's identification using a challenge/response system or similar procedure.
 - B. **A challenge/response system or similar procedure should be the first step in verifying a user's identity. To verify, it is advised that the security administrator should return the user's call after verifying their extension or calling their supervisor for verification.**
 - C. Before an employee is provided with a default password, the individual's identity should be verified using a challenge/response system or similar procedure.
 - D. Before any further action is taken, the user's identity must be verified. A new password should not be generated until it is confirmed, regardless of the security of the terminal.
4.
 - A. Spectertainment has a remote access policy in place that outlines the approved methods for remotely connecting to internal resources but does not address the use of personal devices.
 - B. **An acceptable use policy outlines what employees agree to when using and accessing organizational assets. It would confirm whether the use of personal devices is allowed and may also include a Bring Your Own Device (BYOD) policy to further codify their use.**
 - C. Change control policies are required when making changes to IT systems. While some changes may need to be submitted based on any changes needed to support BYOD, it is not the most important control.
 - D. Access control policies are required to ensure employees understand how to access systems. While changes to the access control policy may need to be made to support BYOD, it is not the most important control.
5.
 - A. **BYOD policies have shown increased productivity and employee satisfaction.**
 - B. BYOD use can make it more difficult to terminate employee access.
 - C. **Since employees are using their own devices, BYOD can help organizations increase their cost savings.**
 - D. The use of BYOD does not indicate that employees have increased awareness of the security risk posed by their use of their personal devices for work.